Webinar Script: Unpacking the Critical PHP Vulnerabilities

Intro Taylor Togami **1**
[Old] Intro **3**
Mike 3
Shweta 3
Mike 4
Discovery Timeline **5**
Taylor 5
Timeline 6
How These Vulnerabilities Affected Palo Alto Networks **7**
Mike 7
ATP+ TME Interview with Kaushal Varshney 7
SOC Team Day in the Life Questions with Tan Nguyen **9**
Questions 9
Outro Taylor Togami **9**

Intro Taylor Togami

Welcome to our Securing AI by design webinar series. Today we will be covering Inside the PHP Vulnerabilities with Palo Alto Networks. I'm Taylor Togami, Solutions Consultant for the NorCal district. I'll be kicking things off with a quick landscape breakdown before handing the mic over to my teammates, Shweta and Mike ( ) , who will host our guest interviews.

[CUE FOR SLIDE 1 - AGENDA SLIDE]

Quick logistics note: If you signed in with your verified Zoom account rather than dialing in by phone, keep an eye on your inbox after this webinar concludes —a DoorDash gift card is on its way.

Here is our agenda for the session:

1. Break down the mechanics and global impact of the PHP2Shell vulnerability.
2. Walk through the discovery timeline, the role of Frontier AI, and the infrastructure fallout.

3. Speak with Product on using Frontier AI to preemptively block zero-days.
4. Interview our SOC team on frontline incident response and remediation.

Let's set the stage. PHP powers over 70% of the web's known server-side code, underpinning platforms like WordPress, Drupal, and low-cost shared hosting environments worldwide. When a core engine issue hits PHP, the ripple effect is massive.

[CUE FOR SLIDE 2 - CVE 618]

The vulnerability is known as **PHP2Shell**, tracked under **CVE-2026-109618** and **CVE-2026-109619**. It allows unauthenticated remote code execution directly inside the PHP core—meaning an attacker can compromise a server even if the site's own application code is completely secure.

It operates as a two-stage exploit chain targeting PHP's crash handling:

- **CVE-2026-109618 (The OOM Crash):** The attacker exhausts server memory to trigger an out-of-memory crash. PHP's emergency cleanup aborts halfway, leaving internal memory corrupted.

[CUE FOR SLIDE 3 - CVE 619]

- **CVE-2026-109619 (The Use-After-Free):** Web servers reuse worker processes across requests. When the recycled worker takes the next request, dangling global pointers still reference that leftover, corrupted memory—tricking PHP into executing it.

Cortex Xpanse has already mapped over 22 million exposed instances across the internet.

What makes this an inflection point is the **Frontier AI** factor. For years, discovering subtle logic flaws in massive legacy codebases was an asymmetrical game favoring attackers with infinite time. Frontier AI is flipping that dynamic. We are no longer talking about LLMs that just autocomplete code; these models exhibit deep reasoning across multi-step execution flows, simulating edge-case crashes that human auditors missed for over a decade.

That shift drove the entire discovery timeline, giving defenders a two-month head start before public disclosure:

- The discovery began in August at the security firm Calif, whose researchers audited PHP source code using GPT-5.6 Sol. That work ran under OpenAI's Patch the Planet initiative. Calif found multiple paths to remote code execution and reported the first bug on August 11.
- **August 24, 2026:** Wiz independently caught the flaw using Gemini 4 Argon alongside their Atlas tooling.
- **September 2026:** OpenAI mapped the complete, extended variant.

This race is critical because attackers have also weaponized it. Threat actors are actively chaining PHP2Shell with the Fragnesia bug (CVE-2026-46300) against exposed admin panels, compromising credentials and MFA secrets in under two hours.

[CUE FOR SLIDE 4 - FIREWALL MGMT]

Regarding Palo Alto Networks: The PAN-OS management web interface on PA-Series, VM-Series, and Panorama is vulnerable **only if** directly exposed to the public internet. Products like GlobalProtect, Captive Portal, Prisma Access, Cortex XDR, and Cortex XSIAM are completely unaffected.

Up next, we're shifting gears from traditional detection to proactive, inline defense. If you've been leaning on legacy IPS and crossing your fingers during patch cycles, the threat landscape has officially moved past signature-based playbooks.

To walk us through the technology closing that gap, I'm thrilled to welcome Kaushal Varshney from the Palo Alto Networks Technical Marketing team. Over to you, Shweta.

[CUE FOR STOP SHARING SCREEN]

ATP+ TME Interview with Kaushal Varshney

Use this Deck as Reference

1. Recently, the industry dealt with critical PHP remote code execution vulnerabilities that can allow an unauthenticated attacker to run code on servers running affected PHP versions. When a critical vulnerability like this drops, security teams are instantly in a race against the clock.
    a. Although most of us understand traditional ATP, can you provide a quick recap of how ATP functions?
    b. **How does Advanced Threat Prevention Plus (ATP+) and, specifically, Frontier Virtual Patching (FVP) fundamentally change that dynamic and eliminate the exposure window for our customers?**

[CUE FOR SLIDE 5 - ATP vs ATP+]

2. During that PHP vulnerability scramble, mitigating the threat before a hotfix could be fully deployed was critical. **Can you explain how FVP's 'Vaulted Virtual Patching' shields unpatched assets proactively, without needing to store or disclose sensitive vulnerability details?**

3. Many customers listen to this and think, 'I already have an Intrusion Prevention System (IPS), aren't I covered?' **How does inline Precision AI and deep learning in ATP+**

fundamentally differ from traditional, signature-based IPS when it comes to stopping zero-day exploits?

[CUE FOR SLIDE 6 - NOVA]

4. With the Nova release, we as a company made a massive leap by moving from 'offline analysis' to true 'inline prevention', stopping 26% more zero-day malware and 60% more injection attacks than traditional sandboxes. We've now also introduced the Critical Defense Program (CDP), where software and infrastructure vendors securely share undisclosed vulnerability data directly with Palo Alto Networks.

   Can you walk our listeners through how the CDP ecosystem feeds into the AI-assisted pipeline of ATP+ and Nova? Specifically, how does this allow you to instantly generate and deploy these virtual patches at machine speed, and what does this mean for customers trying to secure legacy or unpatchable systems without suffering downtime?

   With the **Nova release**, Palo Alto Networks introduced a major leap forward, stating it stops 26% more zero-day malware and detects 60% more injection attacks than traditional sandboxes. **Can you walk our listeners through the mechanics of how Nova achieves this inline, and why moving from 'offline analysis' to 'inline prevention' is so critical today?**

5. Looking at the reality of IT operations, deploying patches across an entire enterprise infrastructure often takes weeks, leaving persistent gaps across the network. **For a customer who is on the fence about upgrading to ATP+ and FVP, how would you quantify the operational ROI and risk reduction they get by automating this defense?**

6. As attackers increasingly use generative AI to morph their attacks and automate zero-day discovery, **how does Palo Alto Networks' proprietary Frontier AI Harness ensure that customers using ATP+ are staying ahead of AI-driven threats?**

Palo Alto Networks is taking aggressive steps to remediate this threat for both our products and our customers' broader environments.

- **Rapid Patching:** PSIRT is rolling out patches across all affected PAN-OS versions (including PAN-OS 12.2, 12.1, 11.2, 11.1, and 10.2). Customers are notified via Security Advisory alerts as updates go live.
- **Frontier Virtual Patching (FVP):** For customers utilizing Advanced Threat Prevention Plus with FVP, protection was deployed preemptively. Threat ID 543004 was released on October 20—before the vulnerability details were public—ensuring zero downtime and zero manual policy changes.
- **30-Day FVP Trial:** To help customers instantly remediate their current risk and protect

against future frontier AI-discovered vulnerabilities, we are offering a complimentary 30-day FVP trial effective through November 30.

SOC Team Day in the Life Questions with Tan Nguyen

Host: We are joined by Tan Nguyen from our very own SOC. We invited him on to give you insight into how we dealt with the vulnerabilities.

Questions

1. Could you start by introducing yourself and giving our audience a quick look into your role and daily responsibilities in the SOC?
2. How are you actively leveraging AI within Palo Alto Networks' SOC operations today?
3. We've all seen the ripples frontier AI models have made in the cybersecurity industry. How has that affected your day to day operations/responsibilities?
4. Could you walk us through the moment your team was first alerted to PHP2Shell and the initial incident response steps you took? (make sure just to cover the 8 hour remediation)
5. How do you partner with Unit 42 and threat research teams across the organization during a critical response like this?
6. What advice would you offer to other SOC teams currently working to protect their infrastructure against critical zero-day vulnerabilities?

Outro Taylor Togami

Thanks, Mike and Tan. And thank you to everyone who joined us today.

If there's one central takeaway from today's breakdown, it's that vulnerability discovery has entered a completely new phase. Defensive teams must operationalize Frontier AI with the same speed and rigor as the researchers finding these bugs.

Before you drop off, three quick action items:

1. **Lock down your perimeter:** Verify that your PAN-OS management interfaces are strictly shielded from public internet exposure. Route all administrative access through

dedicated management networks, jump boxes, or secure internal tunnels. Customers also can activate a free 30 day trial of ATP+ with FVP to start using these features today.

2. **Audit external PHP assets:** Run Cortex Xpanse or your external attack surface tooling to identify unpatched, internet-facing assets and prioritize remediating these vulnerabilities.
3. **Check your inbox:** For those who logged in via your registered Zoom accounts, your DoorDash lunch credit is waiting, along with our post-session packet including answers to the Q&A, and the on-demand recording.

If you want to review your specific environment, validate policy hardening, or dive deeper into our Frontier AI roadmap, reach out to your local account team. Thanks for joining *Securing AI by Design*. Stay safe out there, enjoy your lunch, and we'll catch you on the next session of our series.